

Detecção de rastreamento no Firefox

Avaliação Intermediária de Cibersegurança

Prof. João Eduardo Luisi

Autor: Henry Idesis

27 de setembro de 2026

Relatório técnico do plugin Firefox Privacy Inspector, com metodologia, resultados do DuckDuckGo Privacy Test Pages, comparação entre três sites reais e inventário das evidências entregues.

1. Resumo e escopo

A extensão detecta rastreamento no lado do cliente. Ela observa requisições e domínios de terceira parte, separa cookies de primeira e terceira parte entre sessão e persistentes, acompanha localStorage, sessionStorage e IndexedDB, identifica uso de Canvas, aplica heurísticas de bounce/cookie sync, sinaliza WebSocket de terceiros e sobrescrita de globais, calcula um score de 0 a 100 e permite uma blocklist própria.

O histórico local atual tem seis commits incrementais, concentrados na estrutura inicial, detecção de terceiros, cookies e storage, Canvas/bounce/hijacking, score e blocklist. O código original e a autoria foram preservados; as mudanças desta revisão são localizadas e voltadas a segurança, precisão documental e empacotamento da entrega.

A instalação é feita em `about:debugging#/runtime/this-firefox`, carregando o `manifest.json` como extensão temporária. Não há build nem dependências externas. O README do repositório contém o passo a passo e as limitações.

2. Correção de segurança aplicada

O canal `postMessage` continua sendo usado para transportar telemetria do contexto MAIN para o content script, mas agora só encaminha quatro tipos de evento e valida seus campos. Mensagens administrativas como `get-report`, `get-blocklist` e `add-to-blocklist` não passam mais pelo contexto da página. O background aceita esses comandos apenas quando a origem é uma página própria da extensão.

Também foi corrigida a classificação de Expires inválido: ele não é presumido como cookie persistente. `Max-Age=0` e Expires passado seguem sendo tratados como remoção.

3. Metodologia

A interceptação de requisições se relaciona ao conteúdo de redes da Aula 03. A observação do que a página carrega dialoga com a Aula 05, e a separação entre coletar, processar, analisar e relatar segue a Aula 06. O score usa categorias com pesos e tetos inspirados na discussão de CVSS da Aula 05.

4. Testes do DuckDuckGo Privacy Test Pages

Os testes foram executados em 27 de setembro de 2026 no Firefox 156.0, versão confirmada no `fingerprinting-results.json`. O arquivo `storage-blocking-results.json` possui 54 linhas detalhadas por incluir variantes de `iframe`; 23/25 é o resumo da página principal.

Teste	Esperado	Plugin	Divergência / causa
Storage Blocking	23 mecanismos; WebSQL e service worker cookieStore podem falhar	23/25; IndexedDB visto; local/session não	A página usa atribuição direta, não <code>setItem</code> ; <code>document.cookie</code> não gera <code>Set-Cookie</code> .
Fingerprinting	Datapoints e Canvas observáveis	124 datapoints, 14 falhas; Canvas em <code>toDataURL/getImageData</code> ; score 85	As falhas pertencem aos exercícios; o hook de Canvas funcionou.
Storage Partitioning	Storage isolado por origem/contexto	20 passaram; 1 unsupported (WebSQL); local/session/IndexedDB vistos	WebSQL não é suportado pelo navegador.
Bounce Tracking	Identificador levado entre navegações principais	Não detectado	O relatório reinicia em <code>main_frame</code> ; a heurística cobre recursos da mesma navegação.
Query Parameters	Valores dos quatro links observáveis	Score 100; quatro links conferidos	Sem divergência relevante.
Request Blocking	Domínio na blocklist não responde	21 bloqueadas; <code>serviceworker-fetch</code> escapou	Limitação do <code>webRequest</code> para requisições dentro de Service Worker.
JS objects / js-leaks	Alterações globais detectáveis	Score 100; hijacking não detectado; profile mostra hooks	A página vê a instrumentação, mas o detector não conta os próprios hooks.
Tracker Reporting	Página reporta trackers	Sem coleta independente na entrega original	Pendente de execução manual; nenhum resultado foi inventado.

As divergências foram mantidas explícitas. O teste de bounce expõe a diferença entre acompanhar recursos da mesma navegação e manter estado entre navegações principais. O teste de JS leaks confirma que a página consegue ver os hooks legítimos da extensão; isso é uma limitação conhecida e não foi apresentado como ausência de instrumentação.

4.1 Evidências DDG

Agora o Firefox é aberto automaticamente quando você entra no Windows. Pode mudar isso quando quiser nas configurações. [Saiba mais](#) [Desativar](#)

[\[Home\]](#) > [\[Privacy Protections Tests\]](#) > [\[Storage Blocking Test Page\]](#)

This page will try to store, and then retrieve, a random number using various storage mechanisms in the browser.

[Store data](#) [Retrieve data](#)

► Retrieved data from 23 storage mechanisms (2 failed). Click for details.

[Download the result](#)

broken.uniro-party.site
12 requisição(ões) - tipo(s): script, xmlhttprequest, sub_frame
Classificação Firefox: nenhuma registrada

good.third-party.site
12 requisição(ões) - tipo(s): script, xmlhttprequest, sub_frame
Classificação Firefox: nenhuma registrada

convert.ad-company.site
6 requisição(ões) - tipo(s): sub_frame, script, xmlhttprequest
Classificação Firefox: nenhuma registrada

COOKIES

	Sessão	Persistentes
1ª parte	0	0
3ª parte	0	0

ARMAZENAMENTO LOCAL

- localStorage: não usado
- sessionStorage: não usado
- IndexedDB: **usado (data)**

CANVAS FINGERPRINT
Não detectado

BOUNCE TRACKING / COOKIE SYNC
Não detectado

HIJACKING / HOOK
Não detectado

Storage Blocking — resumo 23/25 e storage observado pelo plugin.

Agora o Firefox é aberto automaticamente quando você entra no Windows. Pode mudar isso quando quiser nas configurações. [Saiba mais](#) [Desativar](#)

[\[Home\]](#) > [\[Privacy Protections Tests\]](#) > [\[Fingerprinting Test Page\]](#)

This page collects various datapoints from your browser that can be used for fingerprinting.

⚠ Please note that:

- not all of the properties listed here have to be modified to successfully prevent fingerprinting,
- depending on the browser some properties may change randomly on every page reload or test run,
- some data is duplicated, but it's retrieved using different methods,
- this page has to be loaded over https for all tests to work correctly (some APIs are not available over http).

[Start the test](#)

- ☐ Include all headers and all properties of window, navigator and screen objects
- ☐ Collect information from events (you will have to invoke those events)

► Collected 124 datapoints (14 failed). Click for details.

[Download the result](#)

[Save result in localStorage](#)

[Compare current result with result from localStorage](#)

Compare current result with result loaded from a file [Procurar...](#) Nenhum arquivo selecionado.

► Canvas visual check

TERCEIRA PARTE
Requisições: 0
Domínios: 0
Bloqueadas: 0
[Gerenciar lista de bloqueio](#)

DOMÍNIOS DETECTADOS
Nenhum domínio de terceira parte detectado.

COOKIES

	Sessão	Persistentes
1ª parte	0	0
3ª parte	0	0

ARMAZENAMENTO LOCAL

- localStorage: não usado
- sessionStorage: não usado
- IndexedDB: não usado

CANVAS FINGERPRINT
Detectado — métodos: toDataURL, getImageData

BOUNCE TRACKING / COOKIE SYNC
Não detectado

HIJACKING / HOOK
Não detectado

Fingerprinting — 124 datapoints, 14 falhas e eventos de Canvas.

Agora o Firefox é aberto automaticamente quando você entra no Windows. Pode mudar isso quando quiser nas configurações. [Saiba mais](#) [Desativar](#)

- you have multiple copies of the test page open
- you run the tests after force reloading the page, as this [bypasses](#) Service Workers

[Run Tests](#)

Retrieved data from 21 storage mechanisms.

[Show Detailed Results](#)

- document.cookie - pass
- HTTP Cookie - pass
- Cookie Store API - pass
- localStorage - pass
- sessionStorage - pass
- IndexedDB - pass
- WebSQL - unsupported
- Cache API - pass
- ServiceWorker - pass
- BroadcastChannel - pass
- SharedWorker - pass
- Web Locks API - pass
- Fetch Cache - pass
- XMLHttpRequest Cache - pass
- Iframe Cache - pass
- Image Cache - pass
- Favicon Cache - pass
- Font Cache - pass
- CSS cache - pass
- Prefetch Cache - pass
- HSTS - pass

[Download the result](#)

privacy-test-pages.site
3 requisição(ões) - tipo(s): image
Classificação Firefox: nenhuma registrada

COOKIES

	Sessão	Persistentes
1ª parte	0	1
3ª parte	0	0

ARMAZENAMENTO LOCAL

- localStorage: **usado (2 chaves)**
- sessionStorage: **usado (1 chaves)**
- IndexedDB: **usado (partition_test)**

CANVAS FINGERPRINT
Não detectado

BOUNCE TRACKING / COOKIE SYNC
Não detectado

HIJACKING / HOOK
Não detectado

Storage Partitioning — 20 passes e WebGL unsupported.

Agora o Firefox é aberto automaticamente quando você entra no Windows. Pode mudar isso quando quiser nas configurações. [Saiba mais](#) [Desativar](#)

[\[Home\]](#) » [\[Privacy Protections Tests\]](#) » [\[Bounce Tracking Test Page\]](#)

Below links allow to bounce of bad.third-party.site to different locations. bad.third-party.site will pass its local UID to the destination via URL param.

[Go to good.third-party.site](#)

[Go to first-party.site](#)

[Go to privacy-test-pages.site](#)

[Go to www.publisher-company.site](#)

ID didn't exist and was generated - "19".

TERCEIRA PARTE

Requisições: 0

Domínios: 0

Bloqueadas: 0

[Gerenciar lista de bloqueio](#)

DOMÍNIOS DETECTADOS

Nenhum domínio de terceira parte detectado.

COOKIES

	Sessão	Persistentes
1ª parte	0	0
3ª parte	0	0

ARMAZENAMENTO LOCAL

- localStorage: **usado (1 chaves)**
- sessionStorage: não usado
- IndexedDB: não usado

CANVAS FINGERPRINT

Não detectado

BOUNCE TRACKING / COOKIE SYNC

Não detectado

HIJACKING / HOOK

Não detectado

Bounce Tracking — identificador novo após a navegação principal.

Agora o Firefox é aberto automaticamente quando você entra no Windows. Pode mudar isso quando quiser nas configurações. [Saiba mais](#) [Desativar](#)

[\[Home\]](#) » [\[Privacy Protections Tests\]](#) » [\[Query Parameters\]](#)

This test page has sample links that use tracking query parameters. When clicking on the sample links the displayed results should be equal to the listed "Expected" value.

URLs with Tracking Parameters

- [Link with utm_source and 1 standard parameter](#)
Expected: "q=other"
- [Link with utm_source and utm_medium](#)
Expected: ""
- [Link with fbclid, fb_source and 1 standard parameter](#)
Expected: "u=14"
- [Link which should not be rewritten](#)
Expected: "q=something&id=1234"

Privacy Inspector

100 Boa

Score de privacidade da página

► Como calculamos

PÁGINA

privacy-test-pages.site

TERCEIRA PARTE

Requisições: 0

Domínios: 0

Bloqueadas: 0

[Gerenciar lista de bloqueio](#)

DOMÍNIOS DETECTADOS

Nenhum domínio de terceira parte detectado.

COOKIES

	Sessão	Persistentes
1ª parte	0	0
3ª parte	0	0

ARMAZENAMENTO LOCAL

- localStorage: não usado
- sessionStorage: não usado
- IndexedDB: não usado

Query Parameters — quatro links e score 100.

Agora o Firefox é aberto automaticamente quando você entra no Windows. Pode mudar isso quando quiser nas configurações. [Saiba mais](#) [Desativar](#)

[\[Home\]](#) » [\[Privacy Protections Tests\]](#) » [\[Request Blocking\]](#)

Testes de bloqueio de requisições:

- HTML
 - script - Try loading a JavaScript file using <script> element.
 - style - Try loading a CSS file using <link> element.
 - img - Try loading an image using element.
 - picture - Try loading an image using <picture> element.
 - object - Try loading an image using <object> element.
 - audio - Try loading an audio file using <audio> element.
 - video - Try loading a video file using <video> element.
 - iframe - Try loading a frame using <iframe> element.
- CSS
 - import - Try loading a CSS file using @import url(.).
 - font - Try loading a font file using @font-face {src: url(.)}.
 - background - Try loading an image using background: url(.).
- JS
 - websocket - Try connecting to a WebSocket.
 - server-sent-events - Try connecting to an EventSource.
 - fetch - Try requesting data using fetch(.).
 - xmlhttprequest - Try requesting data using XMLHttpRequest.
 - sendBeacon - Try sending data using sendBeacon.
- Other
 - favicon - Try loading an image using <link rel="shortcut icon" ...
 - iframe-fetch - Try requesting data from within a first-party iframe.
 - iframe-fetch-depth-2 - Try requesting data from two frames deep (iframe within an iframe).
 - webworker-fetch - Try fetching data from within a WebWorker.
 - serviceworker-fetch - Try fetching data from within a ServiceWorker.
 - csp-report - Try sending data via CSP report.
 - redirected-fetch - Try requesting tracker via redirect through a safe domain.

Privacy Inspector

79 Moderada

Score de privacidade da página

► Como calculamos

PÁGINA

privacy-test-pages.site

TERCEIRA PARTE

Requisições: 0

Domínios: 1

Bloqueadas: 21

[Gerenciar lista de bloqueio](#)

DOMÍNIOS DETECTADOS

bad.third-party.site

0 requisição(ões) - tipo(s): não identificado

Classificação Firefox: nenhuma registrada

COOKIES

	Sessão	Persistentes
1ª parte	0	0
3ª parte	0	0

ARMAZENAMENTO LOCAL

- localStorage: não usado

Agora o Firefox é aberto automaticamente quando você entra no Windows. Pode mudar isso quando quiser nas configurações. [Saiba mais](#) [Desativar](#)

[\[Home\]](#) » **[Detect changes to JS objects in global scope]**

This page checks the global window object for differences versus standard browsers. This shows protections' footprint that are observable and potentially exploitable by the page.

To generate a profile for a new browser load this page there and click "Download this browser's profile" below.

You can also run the test automatically by adding the target browser to the URL, e.g. adding `#chrome_92` to the end of the URL will automatically run comparisons to Chrome.

Compare this browser to: Firefox 92 [Check](#) [Download the results](#)

Properties Added

- ▶ new property `window.AbortController`
- ▶ new property `window.AbortSignal`
- ▶ new property `window.AbstractRange`
- ▶ new property `window.AggregateError`
- ▶ new property `window.AnalyserNode`
- ▶ new property `window.Animation`
- ▶ new property `window.AnimationEffect`
- ▶ new property `window.AnimationEvent`
- ▶ new property `window.AnimationPlaybackEvent`
- ▶ new property `window.AnimationTimeline`
- ▶ new property `window.Array`
- ▶ new property `window.ArrayBuffer`
- ▶ new property `window.AsyncDisposableStack`
- ▶ new property `window.Atomics`
- ▶ new property `window.Attr`
- ▶ new property `window.Audio`
- ▶ new property `window.AudioBuffer`
- ▶ new property `window.AudioBufferSourceNode`
- ▶ new property `window.AudioContext`
- ▶ new property `window.AudioData`
- ▶ new property `window.AudioDecoder`
- ▶ new property `window.AudioDestinationNode`

Privacy Inspector [Atualizar](#) ×

100 *Boa*
Score de privacidade da página
▶ [Como calculamos](#)

PÁGINA
privacy-test-pages.site

TERCEIRA PARTE
Requisições: 0
Domínios: 0
Bloqueadas: 0
[Gerenciar lista de bloqueio](#)

DOMÍNIOS DETECTADOS
Nenhum domínio de terceira parte detectado.

COOKIES

	Sessão	Persistentes
1ª parte	0	0
3ª parte	0	0

ARMAZENAMENTO LOCAL

- localStorage: não usado
- sessionStorage: não usado
- IndexedDB: não usado

JS leaks — score 100 e hijacking não detectado.

5. Três sites reais

Os sites foram worldsurfleague.com, www.apple.com/br/ e www.ralphlauren.pt/. Os números do popup são a leitura da extensão; os números do HAR podem diferir porque o arquivo exportado inclui uma janela de captura e redirects diferentes.

Site	Popup da extensão	Blacklight / uBlock
World Surf League	Score 20; 216 requisições; 58 domínios; 24 cookies persistentes de terceira parte; 23 bounces	12 ad trackers e 2 cookies de terceiro / 13 bloqueios
Apple	Score 92; zero terceiros, cookies 3P, bounce e hijacking; 6 local e 3 session	Limpo / 0 bloqueios
Ralph Lauren	Score 3; 122 requisições; 29 domínios; Canvas, bounce e fetch sobrescrito	0 ad trackers e 0 cookies 3P, mas evasão positiva / 63 bloqueios

No WSL aparecem googlesyndication, doubleclick, scorecardresearch e ps.eyeota. Blacklight conta trackers segundo a própria lista, enquanto o plugin conta domínios externos. No Apple as três ferramentas concordam em um cenário praticamente limpo. No Ralph Lauren, Blacklight indica evasão de bloqueadores, coerente com a presença de terceiros, Canvas e sobrescrita de fetch identificada pelo plugin.

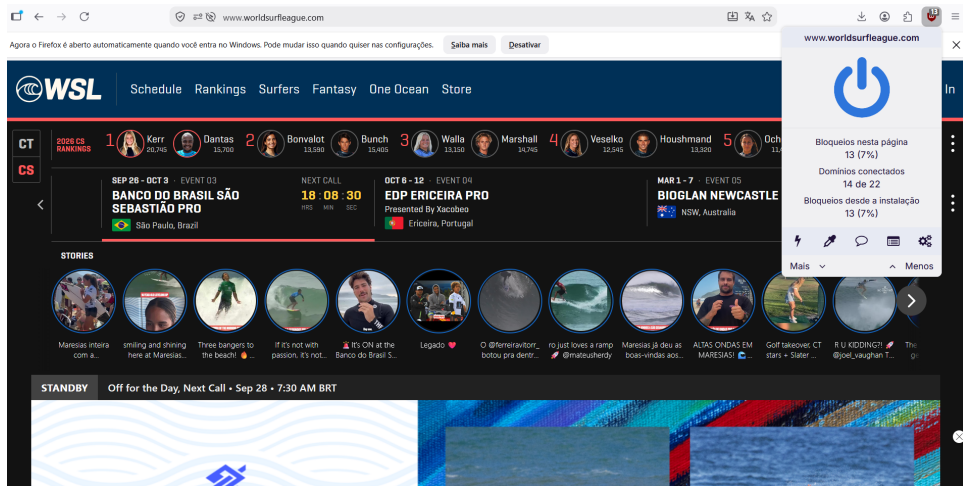
5.1 Reconciliação dos HARs

Site	HAR	Reconciliação
Apple	33 entradas; 2 hosts; 1 Set-Cookie; 0 redirects	0 entradas 3P usando apple.com como base; compatível com o popup.
World Surf League	235 entradas; 60 hosts; 50 Set-Cookie; 19 redirects; 234 entradas 3P	O HAR tem redirects e janela diferente; não deve ser somado ao contador do popup (216/58).
Ralph Lauren	192 entradas; 29 hosts; 38 Set-Cookie; 0 redirects; 97 entradas 3P	Captura diferente do popup; confirma terceiros, mas não substitui o contador 122/29.

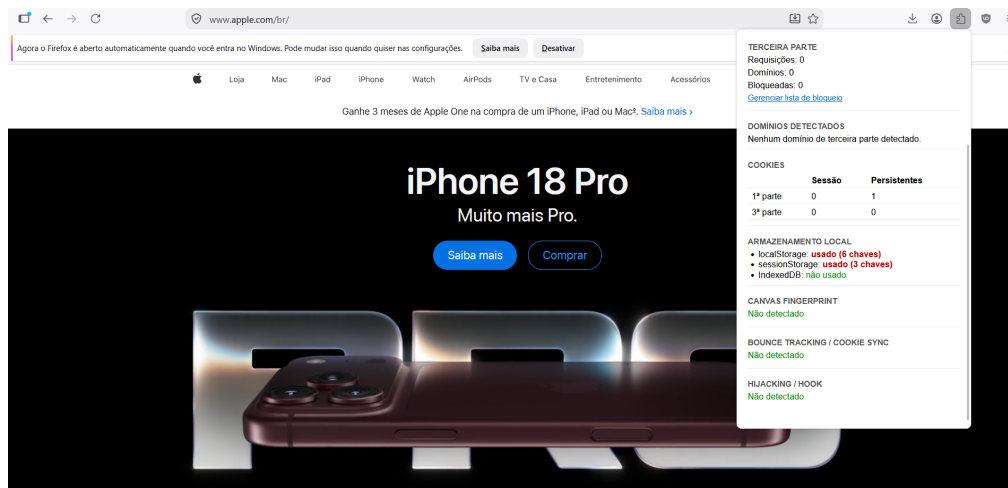
World Surf League

Plugin — score e contadores.

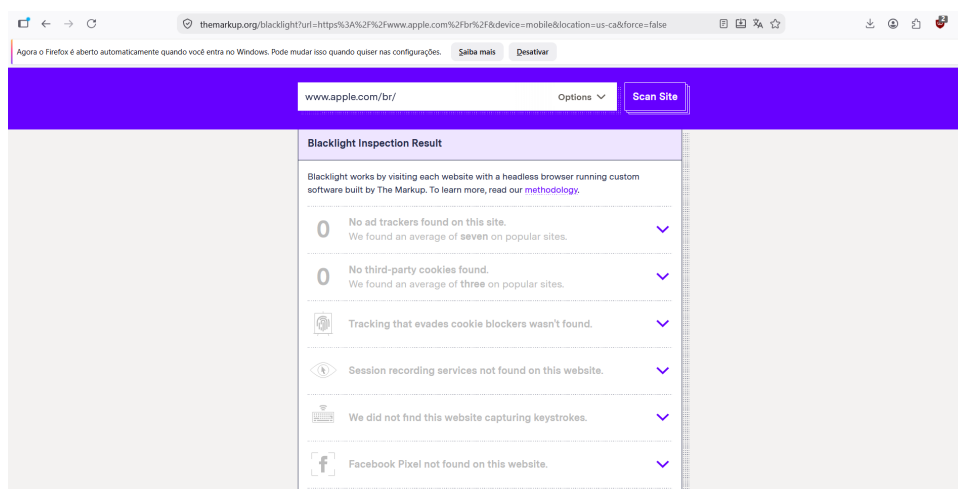
Blacklight — trackers e cookies.



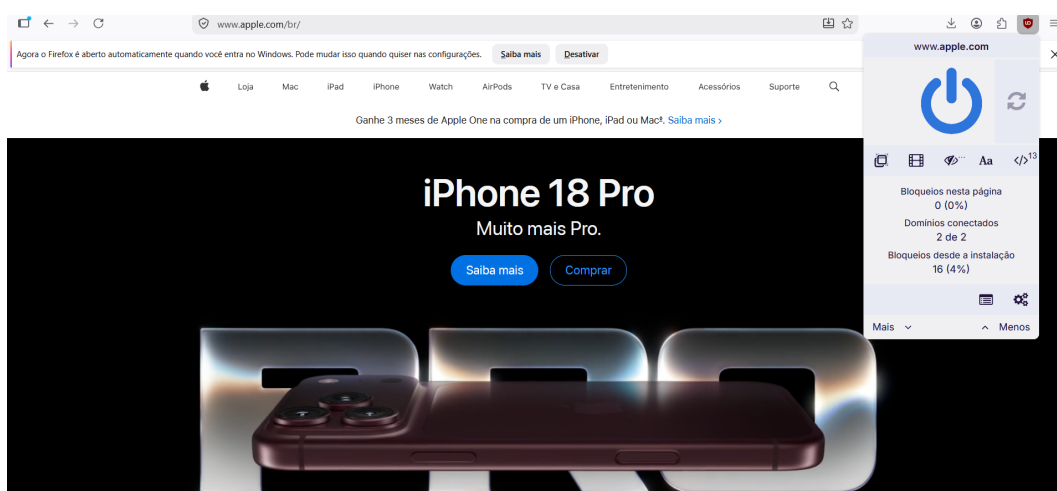
uBlock Origin — bloqueios.



Plugin — cenário limpo e storage local.

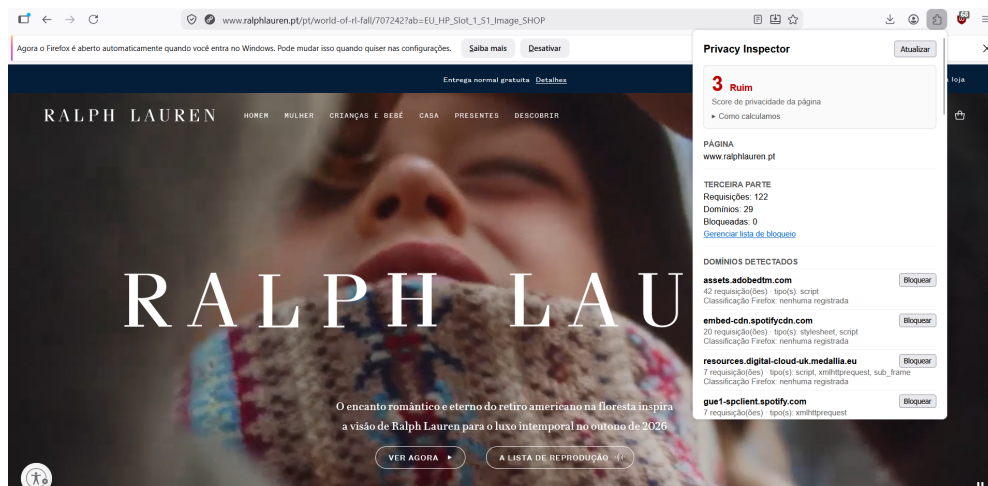


Blacklight — sem trackers.

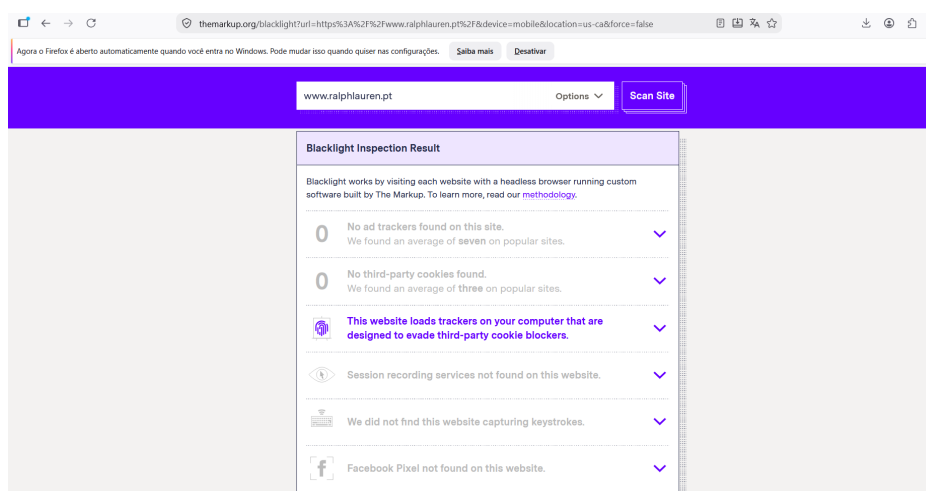


uBlock Origin — zero bloqueios.

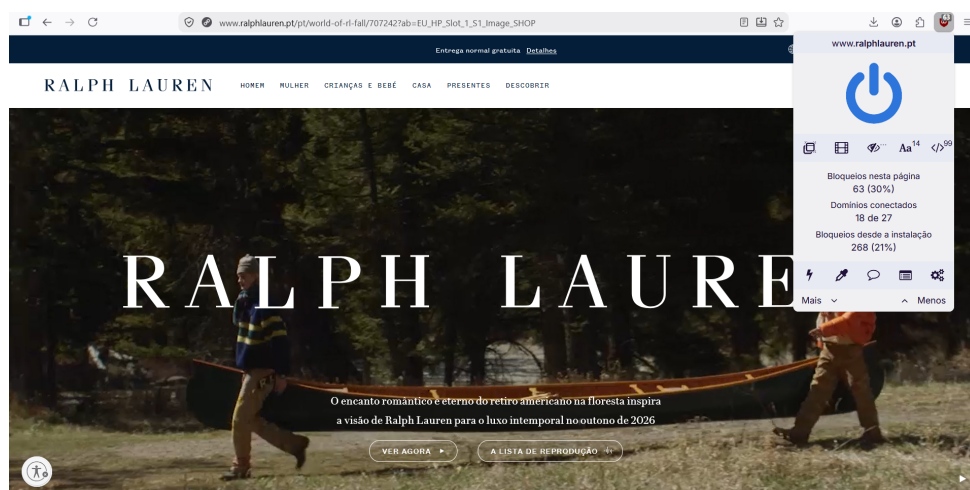
Ralph Lauren



Plugin — score e contadores.



Blacklight — evasão positiva.



uBlock Origin — 63 bloqueios.

6. Metodologia do score

Critério	Penalidade	Unidade	Teto
Domínio de terceira parte	-1	por domínio	-25
Requisição de terceira parte	-0,2	por requisição	-15
Cookie 3P persistente	-2	por cookie	-15
Cookie 3P de sessão	-0,5	por cookie	-5
Cookie 1P persistente	-0,2	por cookie	-3
localStorage / sessionStorage / IndexedDB	-5 / -3 / -5	uma vez	individual
Canvas fingerprint	-15	uma vez	-15
Bounce / cookie sync	-10	uma vez	-10
Hijacking	-20	uma vez	-20

Faixas: 80–100 Boa, 50–79 Moderada, 0–49 Ruim. Aplicação final: Apple 92, World Surf League 20 e Ralph Lauren 3. Hijacking pesa 20 porque sugere alteração da superfície do navegador; Canvas pesa 15 por identificar o dispositivo sem depender de cookie. Recursos externos legítimos recebem peso menor do que sinais diretamente associados a persistência, fingerprinting ou controle.

7. Limitações e checklist

Cookie via JavaScript não aparece no contador de cabeçalho. Storage por atribuição direta não passa pelo hook de setItem. Bounce entre navegações principais perde estado porque o relatório é reiniciado em main_frame. O domínio-base usa uma lista manual de sufixos. Canvas, hijacking e cookie sync são heurísticas e devem ser comparados com o HAR e outras ferramentas.

Item	Situação
Manifest instalável e instruções about:debugging	Concluído
README com reprodução e limitações	Concluído
Relatório Markdown e PDF	Concluído
DDG com divergências e evidências disponíveis	Concluído; Tracker Reporting ainda sem captura independente
Três sites, três HARs, Blacklight e uBlock	Concluído
Score aplicado e reconciliação de contadores	Concluído
Canal de mensagens sem comandos administrativos da página	Concluído

Conclusão: o plugin detecta, classifica, mostra e bloqueia nos cenários demonstrados. As limitações são declaradas e as evidências estão organizadas no repositório. Para uma entrega que exija todos os itens do roteiro sem ressalvas, ainda falta executar a página Tracker Reporting e salvar sua captura/JSON; esse resultado não foi preenchido por inferência.